

מודול 6 — סריקה, מיפוי והערכת חולשות — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 6: סריקה ומיפוי

2.  פתרונות מלאים — מודול 6: סריקה ומיפוי

🎯 תרגילים — מודול 6: סריקה ומיפוי

⚠️ רק על מכונות המעבדה שלך. התקן את **Kioptrix Level 1** (מ-VulnHub) כיעד, באותה רשת Host-Only כמו Kali. פתרונות ב- **solutions.md**.

🚦 לפני שמתחילים — קרא אותי!

- מה צריך לרוץ: מכונת **Kali** ומכונת **Kioptrix Level 1** דולקות, שתיהן על אותה רשת **Host-Only**. ודא שאתה רואה את Kioptrix (בהמשך נגלה את ה-IP שלו).
- איך עובדים על תרגיל: קרא קודם את ה-**README.md** של המודול. לכל תרגיל יש 💡 רמז שמפנה לחומר המדויק, ו-✅ קריטריון הצלחה שאומר מתי סיימת אותו.
- נתקעת? זה בסדר גמור. נסה לבד ~10 דקות, קרא שוב את הסעיף המתאים ב-**README**, ורק אז הצץ ב- **solutions.md** — שם יש פתרון מלא צעד-אחר-צעד לכל תרגיל. אחרי שניסית — אין בוש להציץ.
- טיפ זהב: רשום כל פקודה שהרצת ואת התוצאה. זה יחסוך לך זמן בהמשך ובכתיבת הדוח (מודול 16).

מקרא רמות: 🟢 קל · 🟡 בינוני · 🟠 מתקדם · 🔴 אתגר

חלק א' — גילוי וסריקה בסיסית (🟢🟡)

בחלק זה נהיה **ישירים** — הפקודה המדויקת מופיעה. הקלד אותה (החלף את ה-IP/רשת שלך), וחפש את מה שמצוין.

6.1 🟢 — גלה אילו מכונות חיות בתת-הרשת ומצא את ה-IP של Kioptrix.

```
ip a (בדוק עם) החלף בטווח הרשת שלך # nmap -sn 192.168.56.0/24
```

👁️ **חפש:** שורות `Nmap scan report for 192.168.56.X` — אחת מהן היא Kioptrix (לרוב לא ה-Gateway ולא ה-Kali שלך). ✅ הצלחה: יש בידך את כתובת ה-IP של Kioptrix.

6.2 🟢 — הרץ סריקת פורטים בסיסית על Kioptrix.

```
nmap 192.168.56.101
```

```
# Kioptrix של IP-החלק ב
```

👁👁 **חפש:** עמודת PORT עם open — רשום כל פורט פתוח (למשל 22, 80, 139, 443). ☒ הצלחה: יש לך רשימת פורטים פתוחים.

6.3 — זהה גרסאות שירותים ושומר את הפלט לקובץ.

```
nmap -sV -oN kioptrix.txt 192.168.56.101
```

```
# -sV = גרסאות · -oN = שמור לקובץ טקסט
```

👁👁 **חפש:** בשורת פורט 80 — שם וגרסת שרת ה-Web (למשל Apache 1.3.20). פתח את kioptrix.txt לוודא שנשמר. ☒ הצלחה: יש לך שם שרת web + גרסה מדויקת בקובץ.

6.4 — סרוק את כל 65,535 הפורטים.

```
nmap -p- 192.168.56.101
```

```
# לוקח יותר זמן - זה תקין
```

👁👁 **חפש:** האם הופיע פורט חדש שלא היה בסריקה הבסיסית (6.2)? ☒ הצלחה: השווית בין הסריקה המלאה לבסיסית וזיהית אם יש פורט "נסתר".

חלק ב' — מנייה לפי שירות (🟡🟡)

6.5 — על פורט 80: הרץ whatweb ו-nikto. מה הם חשפו? 💡 רמז: README — **מניית HTTP**; `whatweb http://<IP>` ו-`nikto -h http://<IP>`. ☒ הצלחה: רשמת טכנולוגיות (whatweb) ולפחות ממצא/חולשה אחת מ-nikto.

6.6 — הרץ Directory Brute-Force עם gobuster על שרת ה-Web. אילו ספריות/קבצים נסתרים נמצאו? 💡 רמז: README — **גילוי נתיבים**; `gobuster dir -u http://<IP> -w <wordlist>`. ☒ הצלחה: מצאת לפחות ספרייה/נתיב אחד שלא היה גלוי בדפדפן.

6.7 — על פורט 139/445: הרץ enum4linux -a. מה גרסת ה-Samba? אילו שיתופים/משתמשים נחשפו? 💡 רמז: README — **מניית SMB**; `enum4linux -a <IP>`. ☒ הצלחה: יש לך גרסת Samba + רשימת שיתופים/משתמשים.

6.8 — בדוק אם Kioptrix פגיע ל-MS17-010 עם סקריפט ה-NSE המתאים. 💡 רמז: README — **סקריפטי NSE לחולשות**; `nmap --script smb-vuln-ms17-010 -p445 <IP>`. ☒ הצלחה: הסקריפט החזיר תשובה ברורה (VULNERABLE / לא) ורשמת אותה.

חלק ג' — חקר חולשות (מתקדם)

6.9 — עבור גרסת שרת ה-Web ש-nmap גילה, חפש Exploit עם searchsploit. כמה תוצאות? רשום CVE אחד אם מופיע. 💡 רמז: README — חקר חולשות; <שירות גרסה> searchsploit (למשל searchsploit apache 1.3). ✅ הצלחה: יש לך רשימת Exploits אפשריים לגרסה, ולפחות CVE אחד.

6.10 — עבור גרסת ה-Samba/OpenSSH, חפש ב-searchsploit. האם קיים Exploit ידוע? 💡 רמז: README — חקר חולשות; חזור על searchsploit עבור כל שירות שמצאת. ✅ הצלחה: קבעת לכל שירות אם קיים Exploit ידוע (כן/לא) עם שם.

6.11 — בחר CVE אחד שמצאת, וחפש אותו ב-nvd.nist.gov. מה ציון ה-CVSS שלו? 💡 רמז: README — CVE ו-CVSS; חפש את מזהה ה-CVE באתר וקרא את ה-Base Score. ✅ הצלחה: יש לך ציון CVSS מספרי + רמת חומרה (.../Critical/High).

אתגר מסכם — “דוח מנייה מלא של Kioptrix”

הפק מסמך מנייה מסודר (כמו בעבודה אמיתית) הכולל:

1. פרטי היעד: IP, מערכת הפעלה (אם זוהתה).
 2. טבלת פורטים: פורט | שירות | גרסה | הערה — לכל פורט פתוח.
 3. ממצאי מנייה לכל שירות:
 - HTTP: טכנולוגיות, ספריות נסתרות, ממצאי nikto.
 - SMB: גרסת Samba, שיתופים, פגיעות MS17-010.
 4. חולשות פוטנציאליות: לכל שירות — Exploit/CVE שמצאת ב-searchsploit, עם ציון CVSS.
 5. מסקנה — וקטור התקיפה: כתוב 2–3 שורות: מהי החולשה המבטיחה ביותר לניצול, ולמה. (זה יהיה הבסיס למודול 7!)
- 💡 רמז: כל מה שצריך כבר בידך מתרגילים 6.1–6.11 — רק ארגן אותו. מבנה דוח מלא: מודול 16. ✅ הצלחה: מסמך אחד מסודר שאפשר להראות למישהו, שמסתיים בהמלצה על וקטור תקיפה מנומק.

שמור 📁 — במודול 7 ננצל בפועל את החולשה שזיהית כאן.

רשימת בקרה — לפני מעבר למודול 7

- ☐ אני מבצע Host Discovery ומזהה מכונות חיות
- ☐ אני שולט ב-nmap: פורטים, גרסאות, NSE, שמירת פלט
- ☐ אני מְמַנֶה HTTP (nikto, gobuster) ו-SMB (enum4linux)
- ☐ אני יודע לבדוק חולשות ידועות (MS17-010, –script vuln)
- ☐ אני מחפש Exploits ב-searchsploit ומבין CVE/CVSS
- ☐ אני מתעד את הממצאים בצורה מסודרת

פתרונות מלאים: [solutions.md](#)

פתרונות מלאים — מודול 6: סריקה ומיפוי

נסה לבד ב-missions.md קודם. (הפלט המדויק תלוי בגרסת Kioptrix שלך — הערכים כאן אופייניים ל-Kioptrix Level 1).

חלק א' — גילוי וסריקה בסיסית

6.1

```
nmap -sn 192.168.1.0/24 # התאם לתת-הרשת שלך
```

זוהי את ה-IP שאיננו Kali/Gateway — זוהי Kioptrix.

6.2

```
nmap 192.168.1.10
```

פורטים אופייניים ב-Kioptrix 1: **22 (ssh)**, **80 (http)**, **111 (rpcbind)**, **139 (netbios)**, **443 (https)**.

6.3

```
nmap -sV -oN kioptrix_scan.txt 192.168.1.10
```

תוצאה אופיינית: `OpenSSH, Apache httpd 1.3.20 ((Unix) mod_ssl/2.8.4 OpenSSL/0.9.6b)`
`Samba, 2.9p2`

```
nmap -p- 192.168.1.10
```

לעיתים מתגלה פורט Samba גבוה נוסף שלא היה ב-1000 הנפוצים.

חלק ב' — מנייה לפי שירות

```
whatweb http://192.168.1.10
nikto -h http://192.168.1.10
```

nikto יחשוף לרוב את גרסת `mod_ssl` הפגיעה ואת `OpenSSL 0.9.6b` (חולשה ידועה), וקבצים/הגדרות מיושנים.

```
gobuster dir -u http://192.168.1.10 -w /usr/share/wordlists/dirb/common.txt
```

תוצאות אופייניות: `./cgi-bin` , `/mrtg` , `/manual` , `/usage`.

```
enum4linux -a 192.168.1.10
```

חושף את גרסת ה-Samba (למשל **Samba 2.2.1a**) — גרסה זו פגיעה ל-Exploit ידוע (`trans2open`).

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.10
```

ב-1 Kioptrix (לינוקס ישן) לרוב **לא** פגיע ל-MS17-010 (זו חולשת Windows) — אך זהו תרגול חשוב לזהות מתי כן/לא. על מכונת Windows פגיעה, הסקריפט ידווח **VULNERABLE**.

```
searchsploit apache 1.3.20
searchsploit mod_ssl 2.8
```

ה-Exploit המפורסם: CVE-2002-0082 — **OpenLuck / "OpenFuck" (mod_ssl 2.8.x)**. זהו וקטור הניצול הקלאסי של Kioptrix.

```
searchsploit samba 2.2
```

קיים Exploit ל-(CVE-2003-0201) **Samba trans2open** — וקטור חלופי להשגת גישה.

6.11 חפש CVE-2002-0082 ב-nvd.nist.gov → ציון CVSS גבוה (Critical). זה מצדיק ניצול מיידי.

אתגר מסכם — דוח מנייה לדוגמה

```
# דוח מנייה – Kioptrix Level 1
IP: 192.168.1.10 | OS: Linux (Kernel 2.4, Red Hat)

## פורטים
| פורט | שירות | גרסה | הערה |
|-----|-----|-----|-----|
| 22   | ssh    | OpenSSH 2.9p2 | ישן |
| 80   | http   | Apache 1.3.20 + mod_ssl 2.8.4 | פגיע |
| 139  | smb    | Samba 2.2.1a | פגיע (trans2open) |
| 443  | https  | mod_ssl/openssl 0.9.6b | CVE-2002-0082 |

## מנייה
- HTTP: gobuster מצא /usage,/manual; nikto חשף mod_ssl פגיע
- SMB: enum4linux → Samba 2.2.1a, גלויים שיתופים

## חולשות
- CVE-2002-0082 (mod_ssl "OpenFuck") – גבוה CVSS
- CVE-2003-0201 (Samba trans2open) – וקטור חלופי

## מסקנה – וקטור תקיפה
RCE כ-root → דרך פורט 443 (CVE-2002-0082) mod_ssl הווקטור המבטיח: ניצול.
שני המסלולים מובילים לשליטה מלאה. Samba trans2open: חלופה.
```


עברת? יש לך וקטור תקיפה ברור. במודול 7 ננצל אותו בפועל. המשך למודול 7.